



Fuzzing e Ffuf: Técnicas Avançadas de Segurança Web





O que é Web Fuzzing?

1 Técnica de segurança

Identifica vulnerabilidades através de testes com várias entradas.

2 Testes automatizados

Fornece dados inesperados ou aleatórios para detectar possíveis falhas ou entradas.

3 Objetivo

Encontrar pontos de entrada em aplicações web.

Fuzzing vs. Brute-Forcing

Fuzzing

Lança uma rede mais ampla, usando entradas inesperadas e diversificadas.

- Usa wordlists com padrões comuns e mutações
- Testa reações da aplicação a dados estranhos

Brute-Forcing

Abordagem mais direcionada, tentando sistematicamente várias possibilidades para um valor específico.

- Foca em adivinhar valores como senhas ou IDs
- Tenta encontrar o valor correto por tentativa e erro

Para ilustrar a diferença: imagine tentar abrir uma porta trancada. O fuzzing seria como testar diversos objetos na fechadura — chaves, chaves de fenda e até um pato de borracha — para ver o que funciona. Já o brute-forcing seria como testar metodicamente cada chave em um chaveiro até encontrar a correta.



Conceitos Essenciais do Fuzzing

Wordlist

Lista de palavras, frases ou valores usados como entrada durante o fuzzing.

Payload

Dados reais enviados à aplicação web durante o fuzzing.

Response Analysis

Exame das respostas da aplicação web aos payloads do fuzzer.

Fuzzer

Ferramenta que automatiza a geração e envio de payloads.



Introdução ao Ffuf



Ferramenta de Linha de Comando

Ffuf é executado via terminal para realizar fuzzing web.



Alta Performance

Suporta multithreading para scans rápidos e eficientes.



Versátil

Pode realizar diversos tipos de fuzzing em aplicações web.

Fuzz Faster U Fool

Fuzzing de Diretórios com Ffuf

Selecionar Wordlist

Escolha uma wordlist apropriada para diretórios web.

1

Configurar Comando

Use a sintaxe do Ffuf para definir a wordlist e URL alvo.

2

Executar Scan

Rode o comando e analise os resultados para identificar diretórios existentes.

3

Exemplo de comando:

```
ffuf -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-small.txt:FUZZ -u http://SERVER_IP:PORT/FUZZ
```



Extension Fuzzing

1

Definir Alvo

Escolha a URL base para o fuzzing de extensões.

2

Selecionar Wordlist

Use uma lista de extensões web comuns.

3

Executar Scan

Rode o Ffuf focando nas extensões de arquivo.

4

Analisar Resultados

Identifique as extensões válidas e tecnologias utilizadas.

Exemplo de comando:

```
ffuf -w /usr/share/seclists/Discovery/Web-Content/web-extensions.txt:FUZZ -u  
http://SERVER_IP:PORT/blog/indexFUZZ
```

Fuzzing Recursivo

1 Varredura Inicial

Começa com diretórios principais.

2 Subdiretórios

Explora automaticamente diretórios recém-descobertos.

3 Profundidade Controlada

Define limite para evitar varreduras infinitas.

Exemplo de comando para fuzzing recursivo:

```
ffuf -w /opt/useful/seclists/Discovery/Web-Content/directory-list-2.3-small.txt:FUZZ -u http://SERVER_IP:PORT/FUZZ -recursion -recursion-depth 1 -e .php -v
```

Domain Fuzzing

1

Configuração do /etc/hosts

Adicione o domínio alvo ao arquivo hosts local.

2

Seleção de Wordlist

Escolha uma lista de subdomínios comuns.

3

Execução do Ffuf

Realize o fuzzing de subdomínios com Ffuf.

Comando para adicionar ao /etc/hosts:

```
sudo sh -c 'echo "SERVER_IP dominio.site" >> /etc/hosts'
```

Comando Ffuf para domain fuzzing:

```
ffuf -w /opt/useful/seclists/Discovery/DNS/subdomains-top1million-5000.txt:FUZZ -u https://FUZZ.google.com/
```

Vhosts Fuzzing

1

Identificar IP Alvo

Determine o IP do servidor que hospeda os vhosts.

2

Configurar Cabeçalho Host

Use a flag -H para especificar o cabeçalho Host no Ffuf.

3

Executar Fuzzing

Rode o Ffuf para descobrir vhosts públicos e privados.

Exemplo de comando para vhosts fuzzing:

```
ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt:FUZZ -u http://academy.htb:PORT/ -H 'Host: FUZZ.google.com'
```



Parameter Fuzzing

GET Requests

Fuzzing de parâmetros na URL após o símbolo ?.

```
ffuf -w /opt/useful/seclists/Discovery/Web-Content/burp-parameter-names.txt:FUZZ -u https://presencial.moodle.ufsc.br/user/view.php?FUZZ=key
```

POST Requests

Fuzzing no campo data da requisição HTTP.

```
ffuf -w /usr/share/seclists/Discovery/Web-Content/burp-parameter-names.txt:FUZZ -u https://presencial.moodle.ufsc.br/view.php -X POST -d 'FUZZ=key' -H 'Content-Type: application/x-www-form-urlencoded'
```

Criando Wordlists Personalizadas

1

Identificar Padrão

Determine o formato dos valores esperados pelo parâmetro alvo.

1000

Gerar Lista

Crie uma sequência de valores usando ferramentas como Bash.

∞

Aplicar no Ffuf

Use a wordlist personalizada em seu comando de fuzzing.

Comando para gerar wordlist numérica:

```
bash -c 'for i in $(seq 1 1000); do echo $i >> ids.txt; done'
```

Exemplo de uso da wordlist personalizada:

```
ffuf -w ids.txt:FUZZ -u http://presencial.moodle.ufsc.br/view.php -X POST -d 'id=FUZZ' -H 'Content-Type: application/x-www-form-urlencoded'
```



LET'S FUZZZZZ